Онлайн-дүкеннің қауіпсіздігін талдау және пенетрациялық тестілеу

OWASP Juice Shop · ZAP · SQL Injection демо

Тақырыптың мақсаты

Неге шабуыл жасаймыз

Қауіпсіздікті тексерудің жалғыз жолы — алдымен әлсіз жерлерді табу. Бұл диагностика сияқты.

Нәтиже

Шынайы шабуылды модельдеу арқылы дүкеннің осал жерлерін тауып, қорғау жолдарын көрсету.

Неге қорғаймыз

Табылған әр осалдыққа нақты түзету ұсынысын дайындау, нақты мәселені шешу.

Пенетрациялық тестілеу дегеніміз не?

Жүйенің қауіпсіздігін тексеру үшін нақты шабуылшы сияқты әрекет ету арқылы осал жерлерді табу процесі. Рұқсат етілген, бақыланатын ортада жүргізіледі.

1. Барлау

Жүйе құрылымын, беттерін зерттеу

2. Сканерлеу

Автоматты құралмен осалдық іздеу

3. Шабуыл

Тапқан осалдықты дәлелдеу

4. Түзету

Шешім ұсыну, қайта тексеру

Веб-қосымшаға жасалатын шабуыл түрлері

Шабуыл	Мәні
SQL Injection	Дерекқор сұранысына зиянды код енгізу
XSS (Cross-Site Scripting)	Браузерге зиянды JavaScript енгізу
CSRF	Пайдаланушы атынан рұқсатсыз әрекет жасату
Broken Authentication	Әлсіз кіру/сессия басқаруын пайдалану
IDOR	ID өзгертіп, бөтен деректерге қол жеткізу

Қорғау түрлері

Шара	Нені тоқтатады
Параметрленген сұраныс	SQL Injection
Content Security Policy	XSS
CSRF токені	CSRF
Argon2 хэштеу, қауіпсіз сессия	Broken Authentication
Рұқсатты тексеру (authorization)	IDOR

Қорғау коды: XSS және CSRF

XSS: шығысты экрандау

```
{{ user_input }}
# Jinja2 автоматты
# экрандайды: < > "
```

CSRF: токен тексеру

```
if not compare_digest(
sent, session['csrf']):
abort(400)
```

XSS браузердегі скриптті, CSRF — бөтен сайттан жіберілген сұранысты тоқтатады.

Қорғау коды: Authentication және IDOR

Broken Authentication

```
hash = ph.hash(password)
# Argon2, ашық пароль
# дерекқорда сақталмайды
```

IDOR: рұқсатты тексеру

```
WHERE id=? AND
user_id=session['uid']
```

Пароль хэшпен сақталады, ал әр сұраныс тек иесінің деректерін қайтарады.

Зерттеу ортасы

Нысан

OWASP Juice Shop — әдейі осал жасалған оқу онлайн-дүкені. Нақты сайтты тексеру заңсыз, сондықтан осы ресми құрал қолданылды.

Әдіс

OWASP Top 10 бойынша: барлау → автоматты сканерлеу → қолмен тексеру → талдау → түзету.

Құралдар

Docker, OWASP ZAP (автоматты сканер), браузер, Flask (демо үшін).

ZAP сканерлеу нәтижесі

Табылған ескерту	Деңгейі
Content Security Policy тақырыбы жоқ	Орташа
Междоменная (CORS) қате конфигурация	Орташа
Уақыт белгісі (timestamp) ашық	Төмен
Заманауи веб-қосымша ескертуі	Ақпараттық

Табылған осалдық: SQL Injection

Қауіпті сұраныс үлгісі

```
SELECT * FROM users
WHERE email = '[енгізу]'
AND password = '[енгізу]'
```

Мәні: форма енгізген мәтін тікелей SQL сұранысына қосылса, шабуылшы шартты өзгертіп, аутентификацияны айналып өте алады.

Қауіп: парольсіз кіру, деректерге рұқсатсыз қол жеткізу.

Осал код (SQL Injection-ға ашық)

```
# vulnerable_app.py
email = request.form.get("email", "")
password = request.form.get("password", "")
query = (f"SELECT * FROM users WHERE email = '{email}' "
f"AND password = '{password}'")
row = db.execute(query).fetchone()
```

Неге қауіпті: email өрісіне ' OR 1=1-- жазса, шарт әрқашан ақиқат болып, парольді тексермей бірінші пайдаланушыны қайтарады.

Қорғалған код (шешімі)

```
# secure_app.py
email = request.form.get("email", "")
password = request.form.get("password", "")
query = "SELECT * FROM users WHERE email = ? AND password = ?"
params = (email, password)
row = db.execute(query, params).fetchone()
```

Неге қауіпсіз: ? белгісі параметр, деректер базасы драйвері мәтінді әрдайым жай деректер ретінде қарастырады, SQL команда ретінде емес.

Табылған ескертулерге шешім

Ескерту	Шешім
Content Security Policy (CSP) тақырыбы жоқ	Серверге Content-Security-Policy тақырыбын қосу
Междоменная (CORS) қате конфигурация	Access-Control-Allow-Origin-ды нақты мекенжайға шектеу
Уақыт белгісі (timestamp) ашық	Техникалық тақырыптарды (Server, X-Powered-By) жауаптан алып тастау
Заманауи веб-қосымша ескертуі	Ақпараттық, әрекет қажет емес

Қорытынды

Не істелді

- Juice Shop ZAP арқылы сканерленді
- SQL Injection нақты демонстрацияланды
- Әр осалдыққа шешім ұсынылды

Қорытынды ой

- Қауіпсіздік — үздіксіз процесс
- Шабуыл — диагностика құралы

Назар аударғандарыңызға рахмет